

Dinâmica: O Jogo das Soluções DevSecOps

Documento de Leitura - Cenários Práticos

Tópicos da Aula (Opções de Resposta)

- A Ascensão do DevSecOps
- Pilares da Segurança: CIA e Adicionais
- Security by Design e Responsabilidade Compartilhada
- Segurança como Código e Testes Automatizados
- Desafios e Otimização da Gestão de Vulnerabilidades

Cenários para Análise

Rodada 1: O Gargalo no Lançamento

A equipe de programação adotou metodologias ágeis e agora consegue criar e publicar atualizações no aplicativo três vezes por dia. No entanto, o time de segurança da informação ainda trabalha no modelo tradicional, demorando cerca de uma semana para auditar e aprovar cada alteração, travando totalmente o fluxo de lançamentos da empresa.

Rodada 2: A Contestação da Transferência

Um cliente de um aplicativo bancário afirma categoricamente que não realizou uma determinada transferência de valor elevado. Contudo, o sistema do banco possui logs criptografados e auditáveis que provam que a transação foi originada exatamente pelo dispositivo autenticado e com as chaves digitais exclusivas daquele usuário.

Rodada 3: O Jogo de Empurra

Durante uma revisão técnica, descobriu-se que uma tela de login possuía graves vulnerabilidades de exposição de dados. Ao ser questionado, o desenvolvedor responsável afirmou: "Meu trabalho é apenas garantir que a tela fique bonita e funcione no prazo. Proteger o sistema contra invasões é responsabilidade exclusiva do pessoal de infraestrutura e redes quando o app estiver publicado."

Rodada 4: Revisão Manual Extrema

Para evitar que chaves de acesso ou senhas fiquem expostas diretamente dentro do código-fonte do sistema, um gestor de TI determina que um analista júnior deve ler manualmente, linha por linha, as mais de 10 mil linhas de código geradas pela equipe toda sexta-feira antes do sistema ir ao ar.

Rodada 5: O Mar de Alertas

Um relatório de segurança gerou um alerta apontando a existência de 5.000 falhas no sistema. Desesperada, a equipe de operações parou as atividades e começou a corrigir item por item em ordem sequencial. O problema é que 4.998 eram apenas avisos inofensivos ou falsos positivos, fazendo com que o time perdesse tempo e não percebesse 2 vulnerabilidades críticas que permitiram a invasão real do servidor.